

1. OVERVIEW

An overview of Requirement 3 (“Protect Stored Data”), and its sub-requirements.



REQ. 3: PROTECT STORED DATA

REQ. 3: PROTECT STORED DATA **OVERVIEW**

Requirement 3 (Protect Stored Account Data) is all about making sure that stored CHD is properly protected when the data are at rest.

- It's about using strong encryption, masking information, but also protecting the encryption keys and such elements;

This requirement focuses mostly on:

- Ensuring that you minimize the data stored in the first place, don't store certain data, and that you protect very well those stored;
- Ensuring strong mechanisms (key management, key rotation, and others) for the encryption itself;
- Masking the data shown to various roles as possible;

REQ. 3: PROTECT STORED DATA **OVERVIEW**

The sub-requirements for this requirement include:

- 3.1 Processes and mechanisms for protecting stored account data are defined and understood.
- 3.2 Storage of account data is kept to a minimum.
- 3.3 Sensitive authentication data (SAD) is not stored after authorization.
- 3.4 Access to displays of full PAN and ability to copy PAN are restricted.
- 3.5 Primary account number (PAN) is secured wherever it is stored.
- 3.6 Cryptographic keys used to protect stored account data are secured.
- 3.7 Where cryptography is used to protect stored account data, key management processes and procedures covering all aspects of the key lifecycle are defined and implemented.





REQ. 3: PROTECT STORED DATA

REQ. 3: PROTECT STORED DATA **OVERVIEW**

3.1 Processes and mechanisms for protecting stored account data are defined and understood

- This is our usual sub-requirement. Everything defined, documented, updated, in use;
- Likewise, roles and responsibilities documented, assigned and understood;

This is usually tested through:

- As usual, examining documentation and interviewing personnel regarding whether documentation matches the processes that occur, and whether documented roles and responsibilities also match reality;

REQ. 3: PROTECT STORED DATA

OVERVIEW

3.2 Storage of account data is kept to a minimum

- Our goal here is to have data processes and policies that save as little cardholder data as possible, and discard them as soon as possible;
- We want to limit retention times to the minimum legal/regulatory ones, delete data securely, etc;
- We also need to verify these processes, themselves;
- Deletion must be secure. Logical = 0'd out. Physical = shred;

This is usually tested through:

- Examination of the policies, procedures and processes;
- Interviewing personnel and examining logs of past processes to ensure these are being well-executed;
- Verifying specific mechanisms, such as deletion ones;





REQ. 3: PROTECT STORED DATA

REQ. 3: PROTECT STORED DATA **OVERVIEW**

3.3 Sensitive authentication data (SAD) is not stored after authorization

- This sub-requirement is very simple - SAD must only be temporarily stored to authorize a transaction, and after this is completed, they must be eliminated. Period;
- Whether it's magnetic track contents, card verification codes, or PINs/PIN blocks, none can be saved;
- Notice that these can also be physical, not logical data;

This is usually tested through:

- Examining the company's data repositories to ensure none of these data are, in fact, persistently stored;
- Examining the authorization procedures in particular to examine what happens to SAD data after the process;

REQ. 3: PROTECT STORED DATA **OVERVIEW**

3.4 Access to displays of full PAN and ability to copy PAN are restricted

- The maximum that can be shown from a PAN is the BIN + the last four digits. Nobody can see more than this except clearly defined roles with approved, explicit permissions;
- When using remote- access technologies, PANs cannot be viewed or copied, either;

This is usually tested through:

- Examining interfaces where PANs are consulted, as well as masking mechanisms for PANs, and system configurations;
- Examining the list of roles that have explicit access to full PANs, and the justification for each;





REQ. 3: PROTECT STORED DATA

REQ. 3: PROTECT STORED DATA **OVERVIEW**

3.5 Primary account number (PAN) is secured wherever it is stored

- We cannot store PANs in cleartext. We can calculate hashes, encrypt the PAN, truncate parts, etc. When using multiple methods, we need to ensure the different results cannot be used to reconstruct the PAN;
- Can be encrypted Excel files, USB drives, etc. Just not text;
- When encrypting disks/drives, we either store the PANs in removable media or use additional “unreadability” mechanisms;

This is usually tested through:

- Examining data repositories and audit logs, including app payment logs;
- Verifying media, encryption processes, data repositories;

REQ. 3: PROTECT STORED DATA **OVERVIEW**

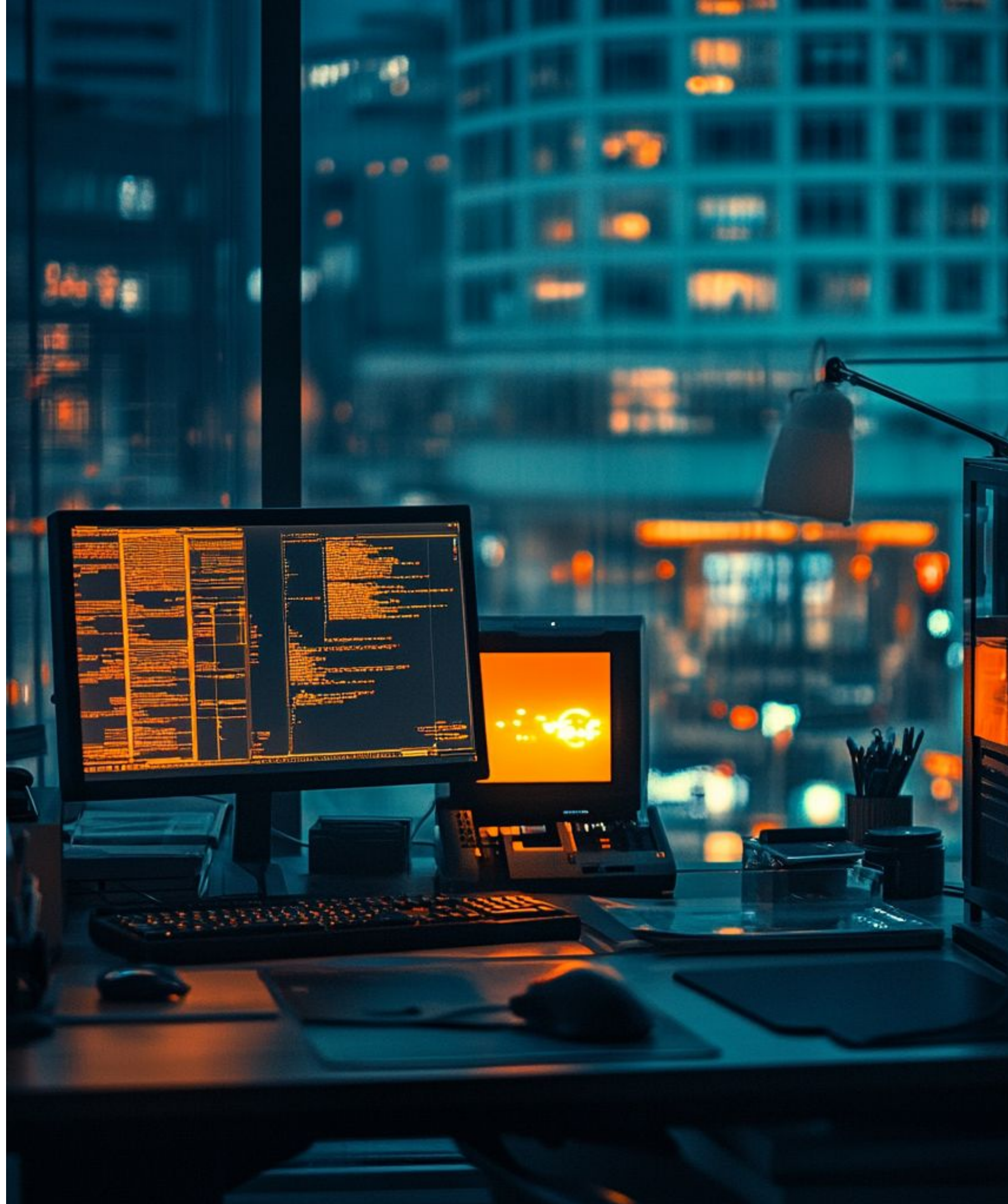
3.6 Cryptographic keys used to protect stored account data are secured

- If using encryption of PANs, we must protect encryption keys, as few people as possible must know these keys, and we must encrypt these encryption keys themselves, with keys that are at least as strong (and stored separately);

This is usually tested through:

- Examining documentation to verify the existence and strength of keys, as well as their storage location(s);
- Examining system configurations to ensure key-encrypting keys are at least as strong as data-encrypting keys;
- Verifying user access lists, key storage locations, etc;





REQ. 3: PROTECT STORED DATA

REQ. 3: PROTECT STORED DATA **OVERVIEW**

3.7 Where cryptography is used to protect stored account data, key management processes and procedures covering all aspects of the key lifecycle are defined and implemented

- Basically, good key management. We must have clear processes to create/distribute/retire keys, have a cryptoperiod for keys (expiration), having acknowledgment by key custodians, split knowledge for cleartext ops, etc;
- Unauthorized replacement of keys must also be forbidden;

This is usually tested through:

- Verifying the key management processes/policies;
- Interviewing personnel and examining storage locations to verify deletion of retired/compromised keys;

REQ. 3: PROTECT STORED DATA **OVERVIEW**

How can we summarize, then, this requirement?

- We must store as least cardholder data as possible, and delete as soon as possible, with formal processes;
- We can never store SAD after transaction authorization;
- We must restrict displaying more than BIN + last four digits of a PAN, and we must render PANs unreadable in storage, be it with hashing/encryption/tokenization/others;
- We must use strong encryption to encrypt PANs in storage, with encryption of the encryption keys themselves, minimizing people with knowledge and storage locations;
- We must have good key management practices, including formal practices for generating / distributing / renewing and/or retiring keys, with cryptoperiods for keys;



REQ. 3: PROTECT STORED DATA

OVERVIEW

EXAMPLES

/01 CLIENT TROUBLE

One unexpected way in which an organisation can receive unsecure card data is if a client sends it (e.g., through email). PCI-DSS failed, and not your fault!

/02 DATA AND KEYS

The encryption keys, themselves, can be a vulnerability. This is which a part of the focus is securing data, but another is securing the keys.

/03 MUST HAVE A REASON

A pattern in this requirement, related to cryptoperiod definition, key management, and other procedures, is similar to others: just pick a period, but have a reason.

REQ. 3: PROTECT STORED DATA

OVERVIEW

USE CASES

SMALL COFFEE SHOP

- The organization ensures it does not store any cardholder data after authorization (both logical, but also paper receipts);
- The organization ensures its machines only print out truncated PANs in receipts;
- The organization stores all paper records in locked cabinets, with restricted access;

E-COMMERCE STORE

- The organization uses strong encryption on databases with card data, and ensures its data policies don't allow storing SAD after authorization in any case;
- The organization replaces PANs with tokens or hashes - or even synthetic data - for many use cases (e.g., data science), to prevent exposure of actual PANs;

HOTEL CHAIN

- The organization consolidates CHD into a secure, centralized system with strict access controls defined by role, to minimize data spread across locations;
- The organization ensures strong cryptographic key management practices, including regular rotation and strong key storage mechanisms;

PAYMENT PROCESSOR

- The organization adopts industry-accepted encryption algorithms and key lengths to encrypt CHD in all repositories/platforms;
- The organization establishes detailed procedures for key generation, distribution, storage, retention and other key lifecycle operations, with strict access controls to encryption keys;

REQ. 3: PROTECT STORED DATA

OVERVIEW

KEY TAKEAWAYS

/01 PROTECTING CHD

This requirement is all about protecting card data. Minimizing the CHD you store, encrypting them, displaying as little as possible, and similar actions.

/03 3.2 MINIMIZING STORAGE

We want to have data policies and processes to minimize the data we store, and deleting them securely after we don't need them anymore.

/05 3.4 NO PAN ACCESS

No more than the BIN + last four digits of a PAN should be viewable, except for very specific roles. In remote access, they should not be copiable, either.

/02 3.1 PROCESSES DEFINED

The usual sub-requirement. Documenting everything and keeping it updated + in use, and having clearly defined roles + responsibilities, also updated + in use.

/04 3.3 NOT STORING SAD

After the authorization step of a transaction, SAD data cannot be stored at all, period, regardless of whether it's magnetic track content, verification codes or PINs.

/06 3.5 SECURING PANs

PANs must be rendered unreadable when they are stored, regardless of mechanism (hashing, encrypting, etc). These must not allow reconstructing the PAN.

REQ. 3: PROTECT STORED DATA

OVERVIEW

KEY TAKEAWAYS

/07 3.6 USING ENCRYPTION

If encrypting PANs, the encryption keys themselves must be protected. We must encrypt these keys, and minimize people with knowledge + storage locations.

/08 3.7 MANAGING ENCRYPTION

We must have good practices for key management, including formal processes for generating keys, distributing them, etc - as well as cryptoperiods.